Clase 2 · Normatividad: estándares de evaluación y de gestión

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · martes 1 sep 2026 · Tema 1 (1.2) · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

> **Fuente**
> **No hay audio** de esta clase. Sale del reporte escrito del Equipo 4 sobre normatividad (SIB-Clase2.pdf), verificado contra el cuaderno de NotebookLM del 26 oct 2026.

Hilo conductor: TCSEC (EE. UU.) + ITSEC (Europa) + CTCPEC (Canadá) → **Common Criteria / ISO/IEC 15408**. En paralelo: BS 7799 → ISO/IEC 17799 → ISO/IEC 27002, en la familia 27000 (**27001 certificable, 27002 no**). Además COBIT, NIST y HIPAA.

1. TCSEC ("Orange Book")

- EE. UU., agosto de **1983**; versión definitiva DoD 5200.28-STD (1985). **Cancelado el 24 oct 2002.**
- Enfoque **monolítico** y militar (casi solo **confidencialidad**); todo recae en la **TCB** (hardware, firmware y software que aplican la política).

Nivel	Significado
D	Protección mínima (MS-DOS)
C1	Discrecional por usuario o grupo
C2	Discrecional controlado + auditorías y reutilización segura de memoria
B1	Seguridad etiquetada; primer nivel **mandatorio (MAC)**
B2	Estructurada; mitiga canales encubiertos
B3	Dominios de seguridad a prueba de manipulación
A1	B3 + verificación formal matemática

2. ITSEC (Europa)

- Mayo 1990 (Francia, Alemania, Países Bajos, Reino Unido); versión 1.2 en junio **1991**.
- **Separa funcionalidad y aseguramiento**; el fabricante define su **Security Target**; evalúa productos y sistemas, no solo SO.
- Niveles **E0** (nula) a **E6** (máxima). Evaluación de corrección y de efectividad (resistencia básica, media, alta).

3. CTCPEC (Canadá)

- Ideado 1988; versión final enero **1993** (v1.0 1989, v2.0 1990, v3.0 1993).
- Tríada **CIA completa** + **Controlabilidad** (identificación, autenticación, auditoría). Híbrido entre TCSEC e ITSEC; evalúa el ciclo de vida; caja blanca y caja negra.
- Garantía **T-0** (inseguro) a **T-6** (formalmente verificado).
- En 1996 se fusiona en Common Criteria.

4. Common Criteria / ISO/IEC 15408 (examen)

Unifica los anteriores; evalúa **productos**, no empresas.

1. Desarrollar el **Security Target (ST)**.
2. Evaluación en un laboratorio acreditado con el **EAL** elegido.
3. Ensayos y revisión del diseño y desarrollo.
4. Certificación por un organismo.

- **PP:** requisitos para una clase de productos (lectores de huella, tarjetas inteligentes). **ST:** especificación de un producto concreto. **EAL1** (básico) a **EAL7** (militar).

5. BS 7799 e ISO/IEC 17799

- **BS 7799** (British Standards Institution, 1995; BS 7799-2 en 1998): introdujo el **SGSI** (la seguridad como gestión de riesgos de toda la organización). Parte 1: buenas prácticas; Parte 2: especificación certificable.
- **ISO/IEC 17799:** código de práctica (no certificable); **11 dominios, 39 objetivos de control, 133 controles**. Ediciones 2000 y 2005; en 2007 se renombró **ISO/IEC 27002:2005**.

6. Familia ISO/IEC 27000 (examen)

Norma	Qué es
27000	Visión general y vocabulario del SGSI (versión 3 jul 2026; JTC 1/SC 27)
27001	**Requisitos** del SGSI; enfoque basado en riesgos; **certificable**; oct 2022 + enmienda 2024; cláusulas 4–10: contexto, liderazgo, planificación, apoyo, operación, evaluación, mejora
27002	**Controles** y buenas prácticas (marzo 2022); no certificable; apoya a la 27001
Categoría 27002:2022	Controles
Organizacionales	37
Humanos	8
Físicos	14
Tecnológicos	34

7. HIPAA, NIST, COBIT

- **HIPAA:** ley federal de EE. UU., 1996; protege la **PHI** y la **ePHI**; salvaguardas administrativas, físicas y técnicas; reglas de privacidad, seguridad y notificación de brechas. Vigente.
- **NIST:** fundado el 3 de marzo de 1901; agencia **no reguladora**; FIPS y serie **SP 800**; **CSF** 1.0 (2014), 1.1 (2018), **2.0 (26 feb 2024)**.
- **COBIT** (ISACA, 1996; vigente **COBIT 2019**): gobierno y gestión de TI; capacidad de procesos **0–5**; **40 objetivos** en **5 dominios**: EDM, APO, BAI, DSS, MEA.

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

Estándar	Origen	Escala
TCSEC	EE. UU. 1983	D, C1, C2, B1, B2, B3, A1
ITSEC	Europa 1991	E0–E6
CTCPEC	Canadá 1993	T-0–T-6
Common Criteria	ISO/IEC 15408	EAL1–EAL7
COBIT	ISACA 1996	Capacidad 0–5; 5 dominios

Lo más preguntable

27001 = requisitos del SGSI, **certificable**. 27002 = controles, no certificable; 2022: 37 + 8 + 14 + 34 = **93** controles en 4 categorías. CC evalúa productos con PP, ST y EAL.